

Unit IV

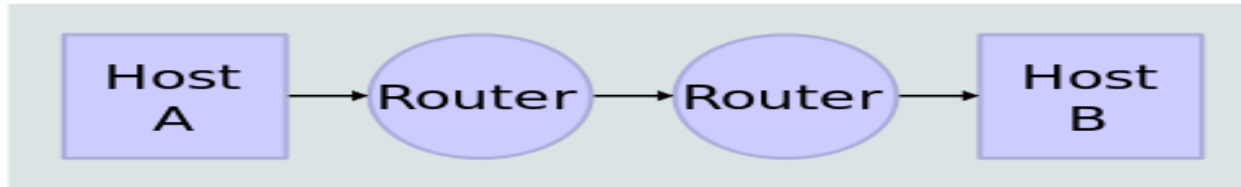
IP Security

Outline

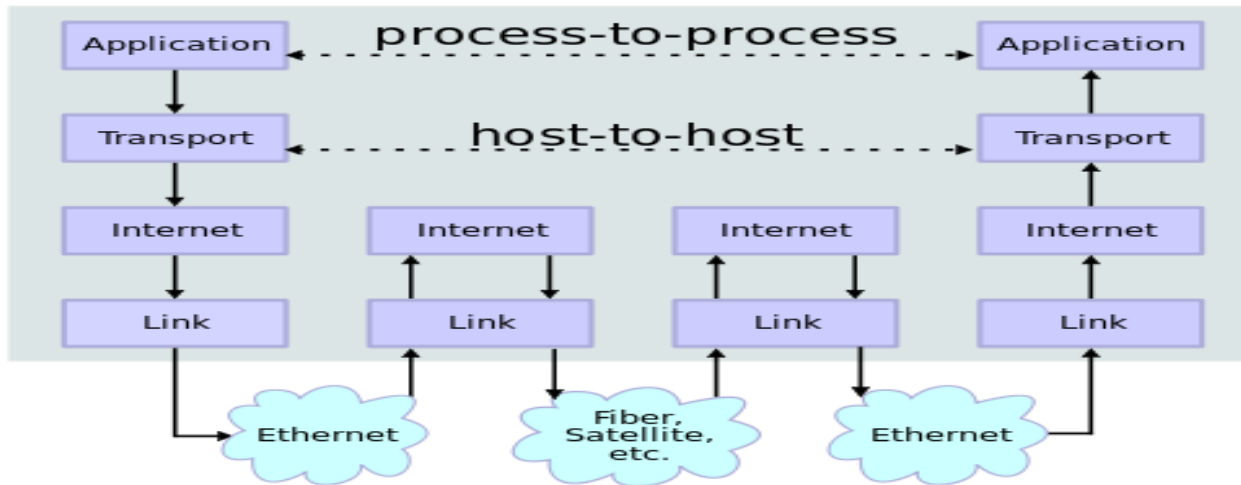
- Internetworking and Internet Protocols (Appendix 6A)
- IP Security Overview
- IP Security Architecture
- Authentication Header
- Encapsulating Security Payload
- Combinations of Security Associations
- Key Management

TCP/IP: Network Topology and Data Flow

Network Topology



Data Flow



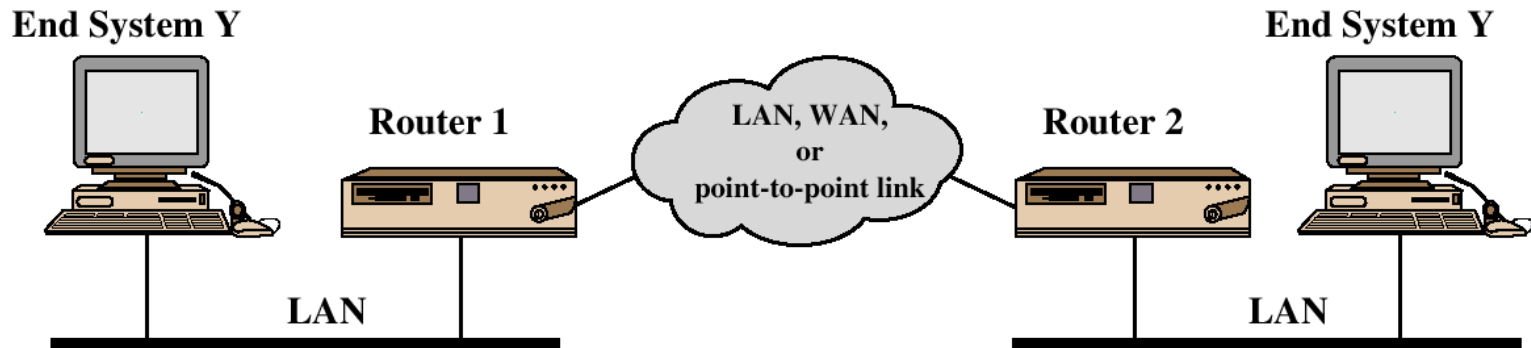
Application Specific
Security Mechanisms:
(PGP, S/MIME)-
Email,
Kerberos-Cleint-
Server,
Secure Socket Layer
(SSL) - Web Access.

IPSec Mechanism; Implements security at the IP level.

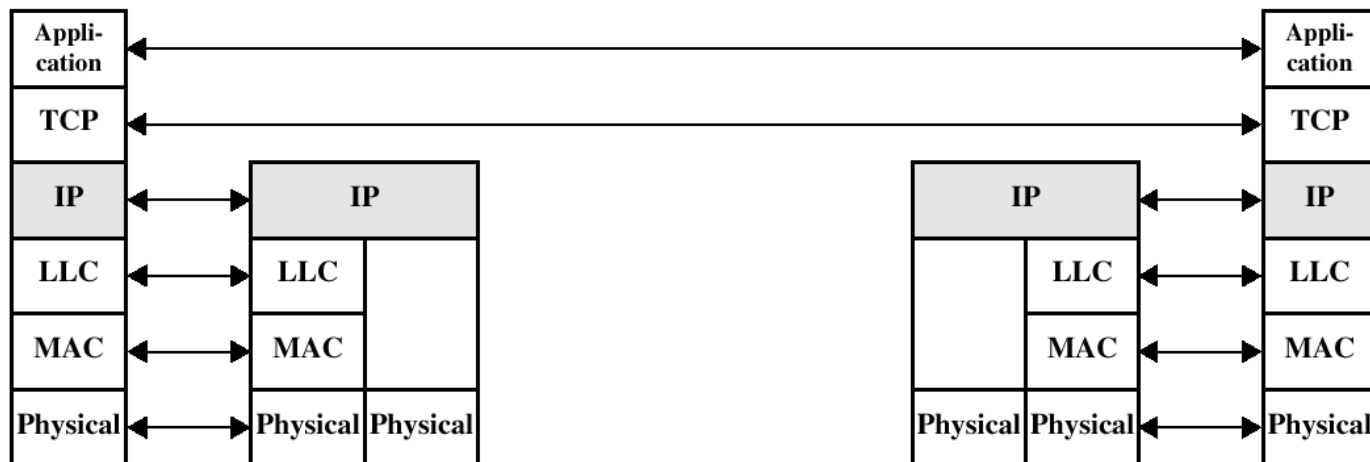
This ensures secure networking not only for application with secure mechanisms but also for many security-ignorant applications.

Role of Internet Protocol (IP)

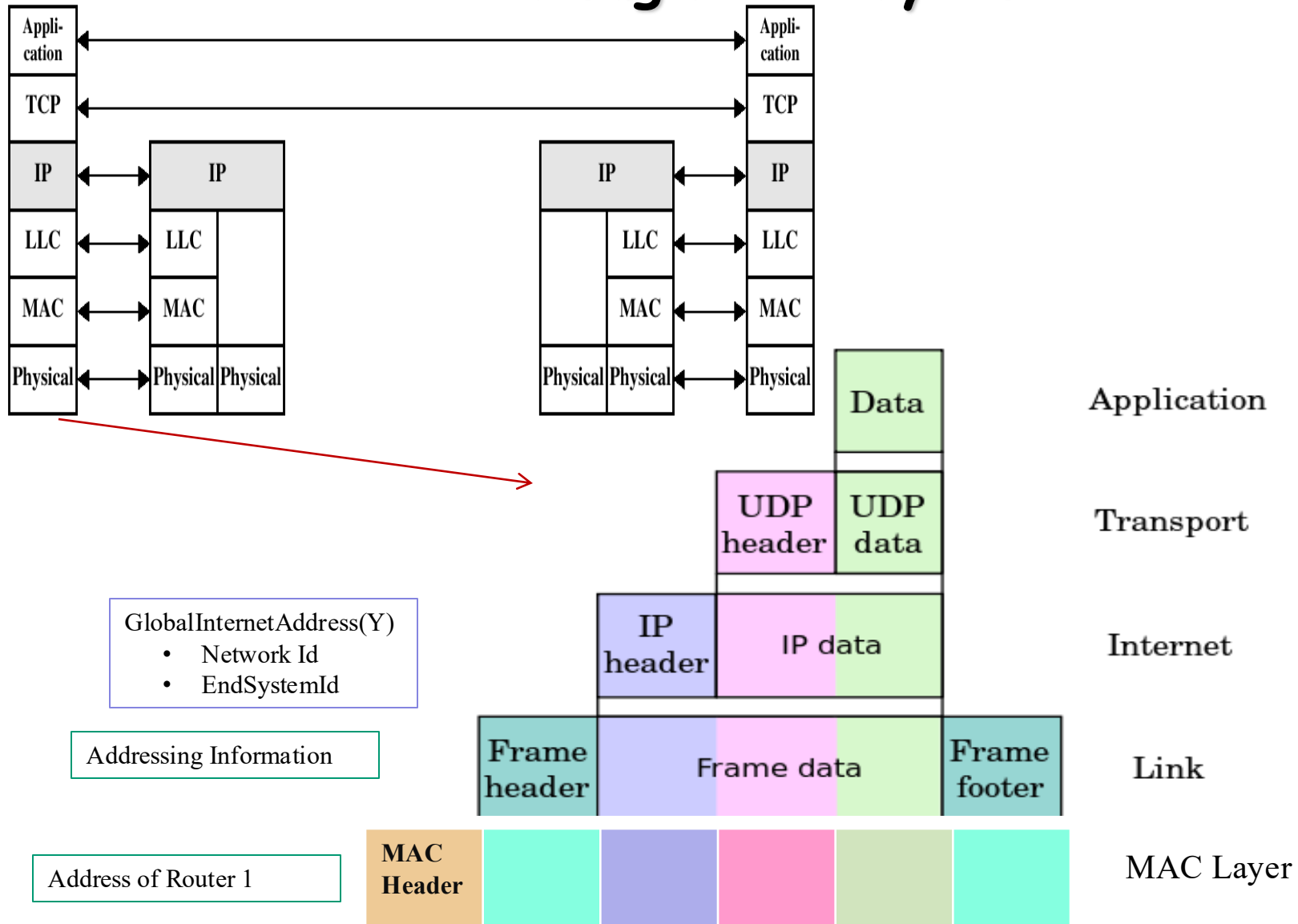
IP provides end-to-end connectivity between systems specifying how data should be packetized, addressed, transmitted, routed and received at the destination.



TCP/IP Example



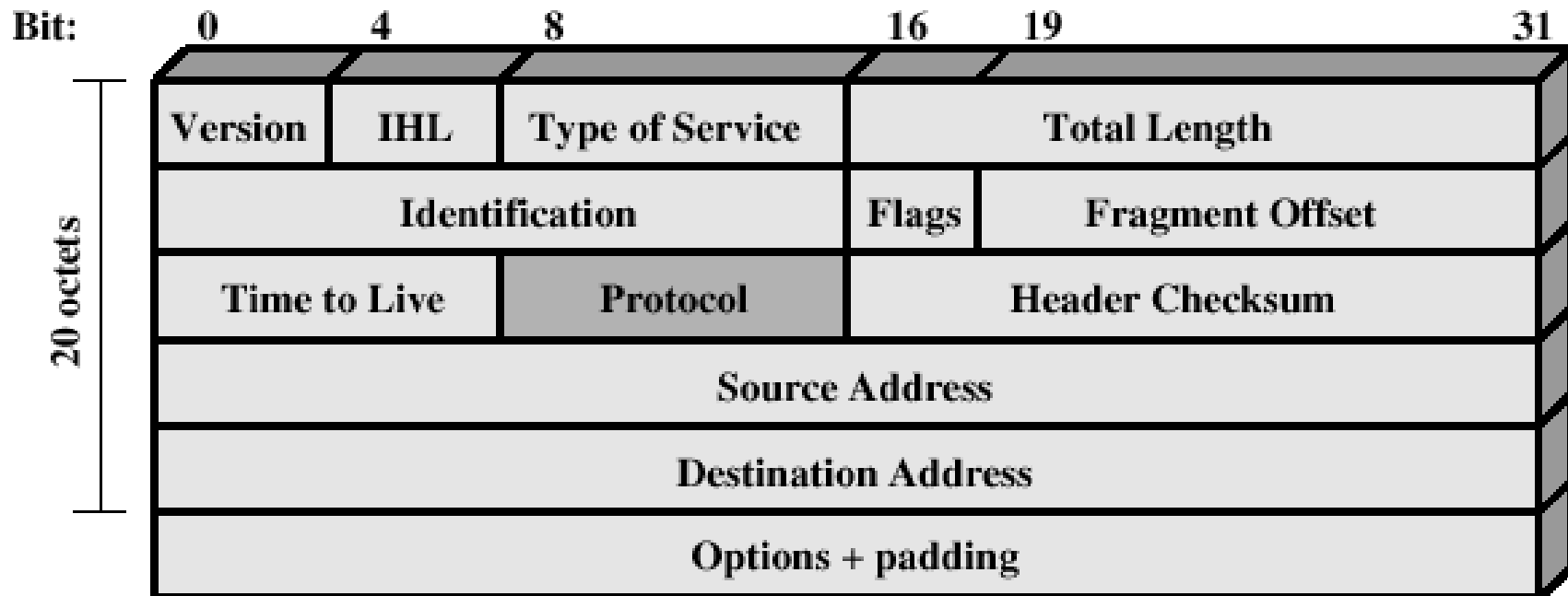
Encapsulation of application data descending through the layers



IP and Router

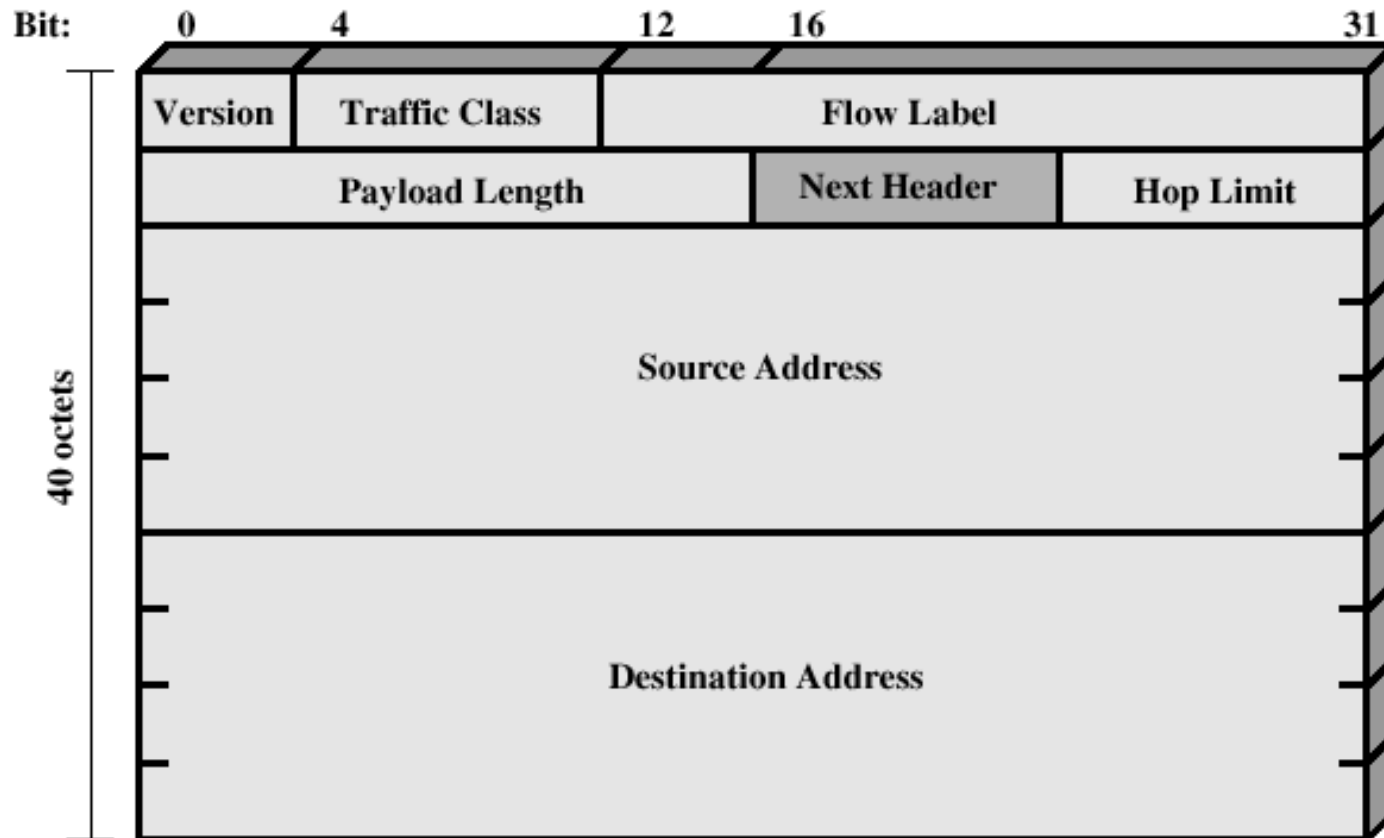
- For interconnecting, IP is implemented in each end system and routers (router: device to provide connection between networks).
- Router must be able to cope with variety of differences:
 - Addressing schemes
 - Maximum Packet Size
 - Interfaces
 - Reliability

IPv4 Header



160 bits: 5 x 32-bit words

IPv6 Header



Total: 320 bits: 10 x 32-bit words.

2 32-bit words for version, payload details.

8 32-bit words=128-bit addresses for source and destination each.

Ipv6 : Extension Headers (EH)

intrinsic part of the IPv6 protocol

they support some basic functions and certain services.

carry optional Internet Layer information

Placed between the fixed header and the upper-layer protocol header.

The headers form a chain, using the Next Header fields.

The following is a list of EHs are commonly used:

1. **Hop-by-Hop EH** Defines special options that require hop-by-hop processing.
2. **Routing EH** provides extended routing, similar to IPv4 source routing
3. **Fragmentation EH** contains fragmentation and reassembly information
4. **Destination Options Header EH** Contains optional information to be examined by the destination node.
5. **Authentication EH** provides packet integrity and authentication
6. **Encapsulating Security Payload EH** provides privacy

Order of the IPv6 headers

1. IPv6 main header
2. Hop-by-Hop Options header (if present, it **MUST** be the first one following the main/regular header)
3. **Destination Options header**
4. Routing header
5. Fragment header
6. Authentication header
7. Encapsulating Security Payload header
8. **Destination Options header**

Significance of IPSec

- IPSec Mechanism; Implements security at the IP level.
- This ensures secure networking not only for application with secure mechanisms but also for many security-ignorant applications.
- IPSec is a capability that can be added to either current version of the Internet Protocol (IPv4 or IPv6), by means of additional headers.
- It encompasses 3 functional areas: Authentication, Confidentiality and Key Management.

IP Security Overview

IPSec is not a single protocol.

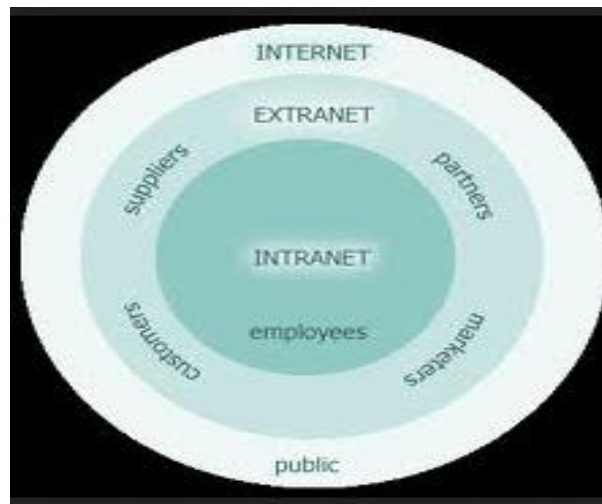
Instead, IPSec provides

- a set of security algorithms
- general framework that allows a pair of communicating entities to use whichever algorithms provide security appropriate for the communication.

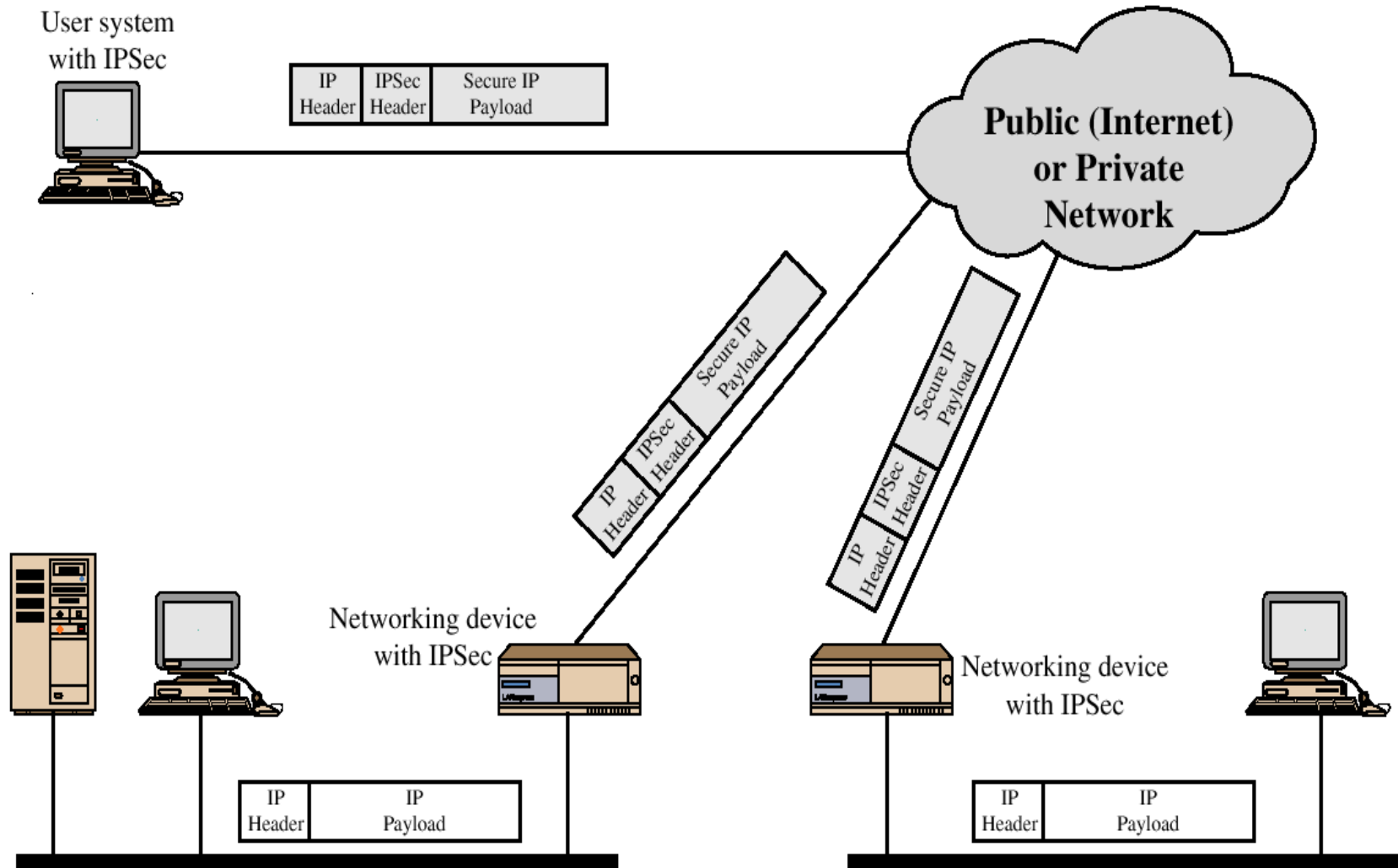
IP Security Overview

- Applications of IPSec

1. Secure branch office connectivity over the Internet
2. Secure remote access over the Internet
3. Establishing extranet and intranet connectivity with partners
4. Enhancing electronic commerce security



IP Security Scenario



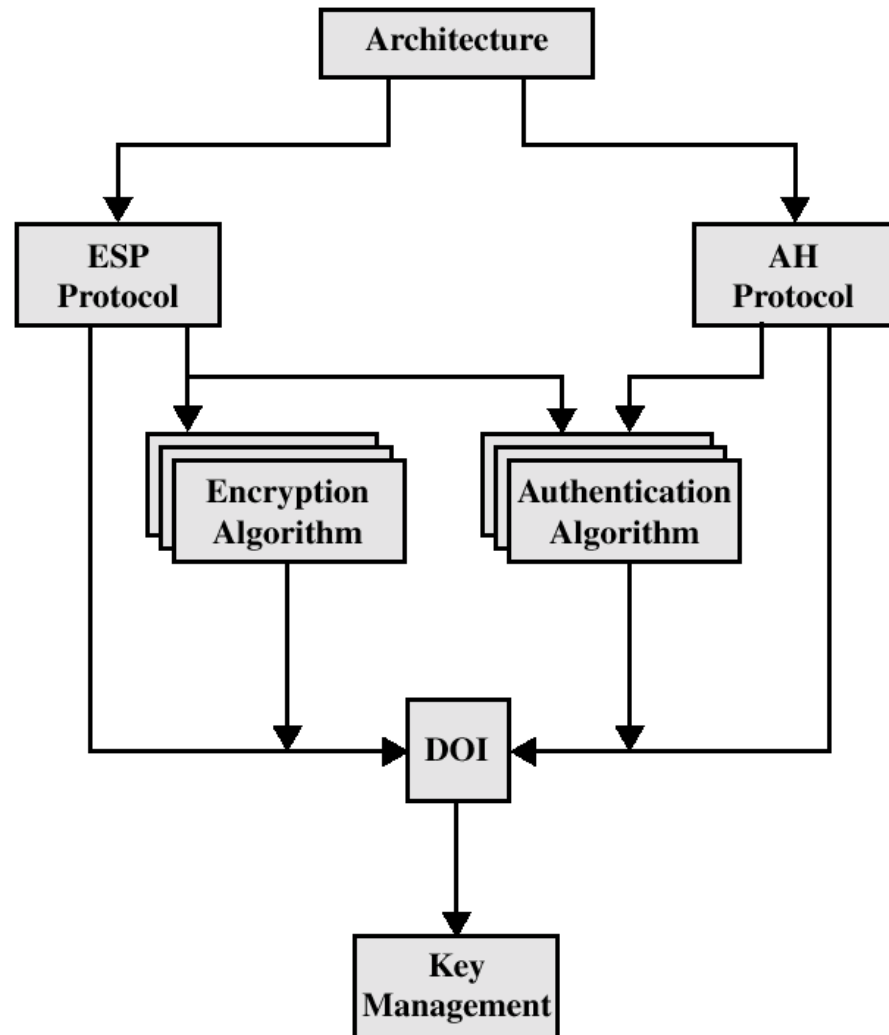
IP Security Overview

- Benefits of IPSec
 - Transparent to applications (IPSec lies below transport layer (TCP, UDP))
 - Provide security for individual users
- IPSec can assure that:
 - A router or neighbor advertisement comes from an authorized router
 - A redirect message comes from the router to which the initial packet was sent
 - A routing update is not forged

IP Security Architecture

- IPsec documents:
 - RFC 2401: An overview of security architecture
 - RFC 2402: Description of a packet authentication extension to IPv4 and IPv6
 - RFC 2406: Description of a packet encryption extension to IPv4 and IPv6
 - RFC 2408: Specification of key management capabilities

IPSec Document Overview



IPSec Services

IPSec provides security services at the IP layer by enabling a system to

- Select required security protocols
- Determine algorithms to use for services
- Establish the keys required for services.

Services

- Access Control
- Connectionless integrity
- Data origin authentication
- Rejection of replayed packets
- Confidentiality (encryption)
- Limited traffic flow confidentiality

Services provided by the AH and ESP protocols

IPSec uses two distinct **protocols**, defined by the IETF

- **Authentication Header (AH) and**
- **Encapsulating Security Payload (ESP),**

Mechanism (AH) - Authentication only.

Services (AH) - Data integrity, data origin authentication, and an optional replay protection.

Mechanism (ESP) – Confidentiality + Authentication

Services(ESP) - confidentiality, data origin authentication, connectionless integrity, an anti-replay service (a form of partial sequence integrity), and (limited) traffic flow confidentiality

Security associations (SA)

(1-way logical connection between 2 devices)

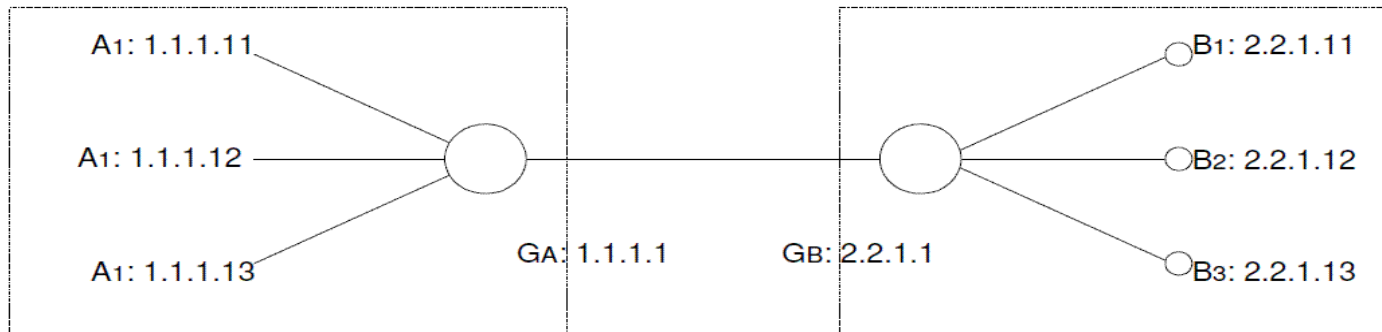
- SA is the establishment of shared *security* attributes between two network entities to support *secure* communication
- A *one-way* relationship between a sender and a receiver system
- Used either for AH or for ESP but never for both
- an SA is uniquely identified by three parameters
 - Security Parameters Index (SPI)
 - a 32 bit string assigned to uniquely identify a particular SA for any connected device
 - carried in AH and ESP headers to allow the receiving party to select the SA which must be used to process the packet
 - IP destination address
 - address of an end-system or a network element (e.g., router)
 - security protocol identifier
 - indicates whether the SA is an AH or an ESP SA

SA parameters

- **sequence number counter**
 - counts the packets sent using this SA
- **sequence counter overflow flag**
 - indicates whether overflow of the sequence number counter should prevent further transmission using this SA
- **anti-replay window**
 - used to determine whether an inbound AH or ESP packet is a replay
- **AH / ESP information**
 - algorithm, key, and related parameters
- **lifetime**
 - a time interval or byte count after which this SA must be terminated
- **protocol mode**
 - **tunnel or transport mode**
- **path MTU**
 - any observed maximum transmission unit

Security Policy Database (SPD)

1. policies that determine the nature of all IP traffic inbound or outbound from a host or a security gateway
2. specify what traffic should bypass IPSEC and what should be dropped, so it must also be consulted for incoming non-IPSEC traffic.



index	Direction	Local IP(sharing?)	Local port(sharing?)	Remt ip(sharing?)	Remt port(sharing?)	Protocol(sharing?)	Inbound 1st SA entry	Outbound 1st SA entry	Action	Policy 1st content
9	In & Out	1.1.1.12 Y	80 Y	2.2.1.0/24 Y	Any Y	TCP Y	sa15	sa25	IPSEC	Cont1
8	In & Out	1.1.1.0/24 Y	Any Y	2.2.1.0/24 Y	Any Y	Any N	sa10	sa20	IPSEC	Cont3
.	...									
...	In									
...	Out									
0	In & Out	Any	Any	Any	Any	Any	NULL	NULL	BYPASS	NULL

Table 1: SPD table at GA (Suppose we have 10 policy entries at GA)

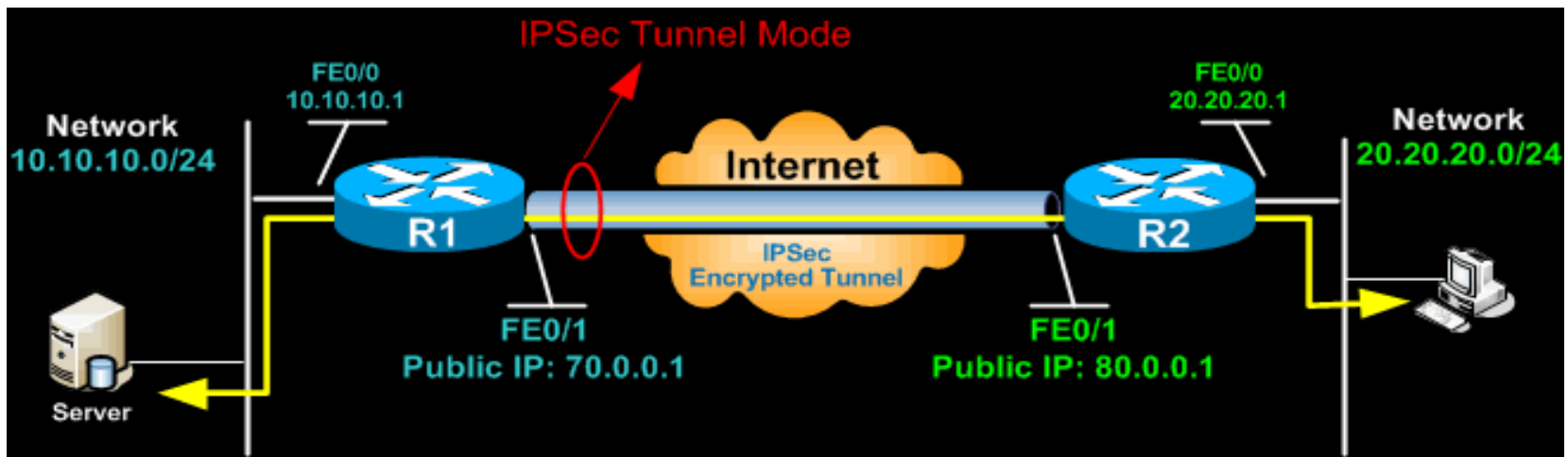
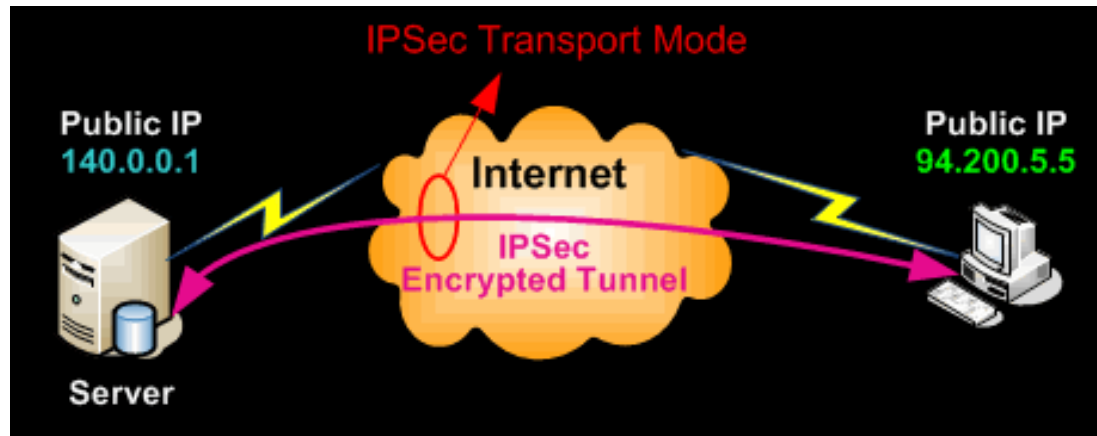
SA selectors

- Security Policy Database (SPD)
 - each entry defines a subset of IP traffic and points to the SAs to be applied to that traffic
 - subset of IP traffic is defined in terms of selectors
 - destination IP address (single, enumerated list, range, or mask)
 - source IP address (single, enumerated list, range, or mask)
 - transport layer protocol (single, enumerated list, or range)
 - destination port (single, enumerated list, range, or wildcard)
- outbound processing
 - compare the selector fields of the packet to the values in the SPD
 - determine which SAs should be used for the packet and their SPIs
 - do the required IPSec processing

Security Policy Database (SPD) and Security Association Database (SAD)

- SPD specifies the policies that determine the disposition of all IP traffic inbound or outbound from a host or a security gateway.
- SAD is a security association table, containing parameters that are associated with each security association.
- http://wiki.treck.com/Security_Policy_Database_SPD_and_Security_Association_Database_SAD

Modes of operation - transport and tunnel mode

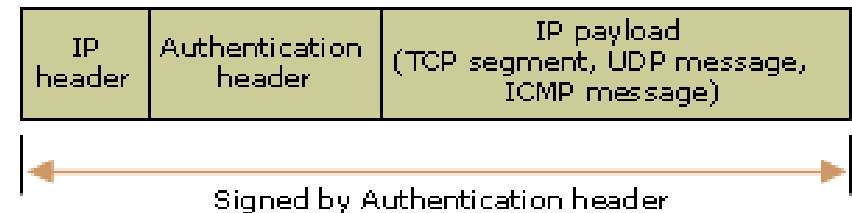
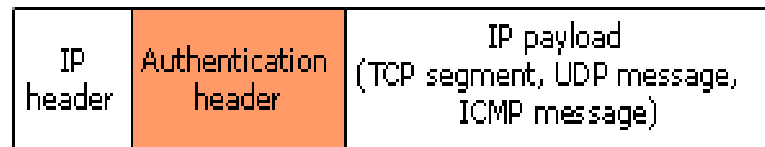


Modes of operation – transport and tunnel mode

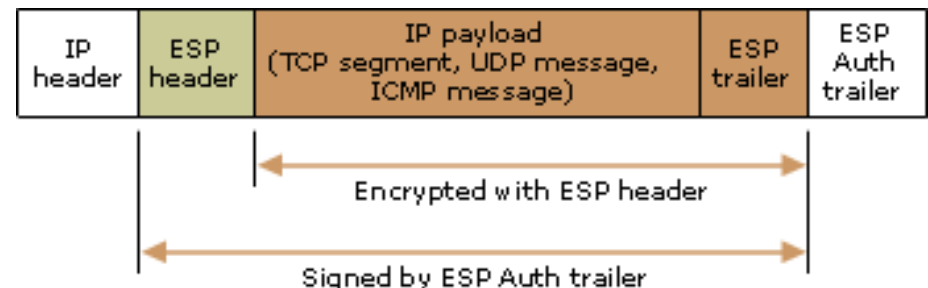
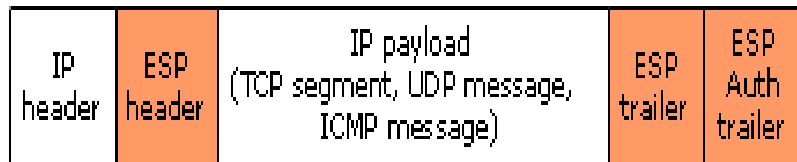
Purpose of Modes of Operation: Interoperability

1. transport mode

- default mode
- provides protection primarily for **upper layer protocols**
- usually used between end-systems
- **protection is applied to the payload of the IP packet**
 - AH in transport mode authenticates the IP payload and selected fields of the IP header

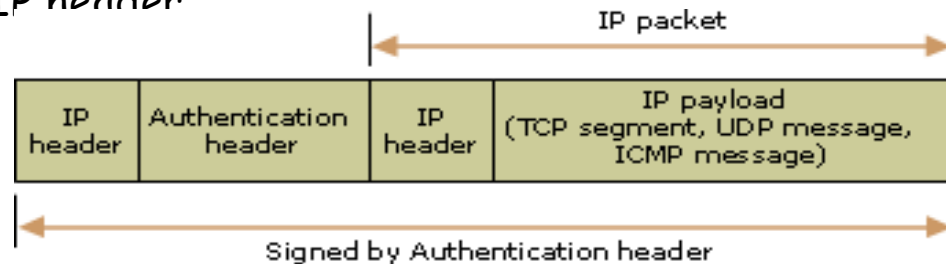


- ESP in transport mode encrypts and optionally authenticates the IP payload but not the IP header

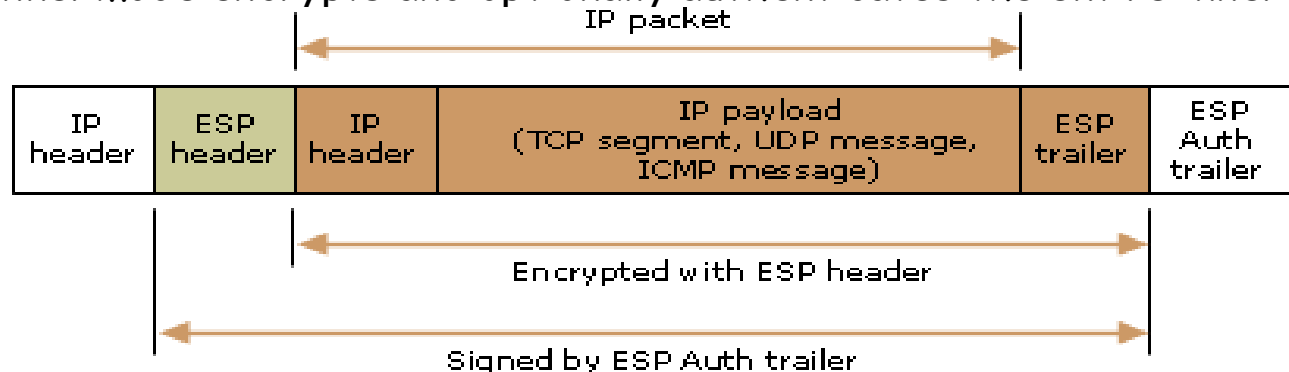


2. tunnel mode

- usually used between security gateways (routers, firewalls) for interoperability like Gateway-to-gateway, Server-to-gateway, Server-to-server
- useful for protecting traffic between different and untrusted networks
- provides protection to the entire IP packet
- the entire IP packet is considered as payload and encapsulated in another IP packet
 - AH in transport mode authenticates the entire inner IP packet and selected fields of the outer IP header

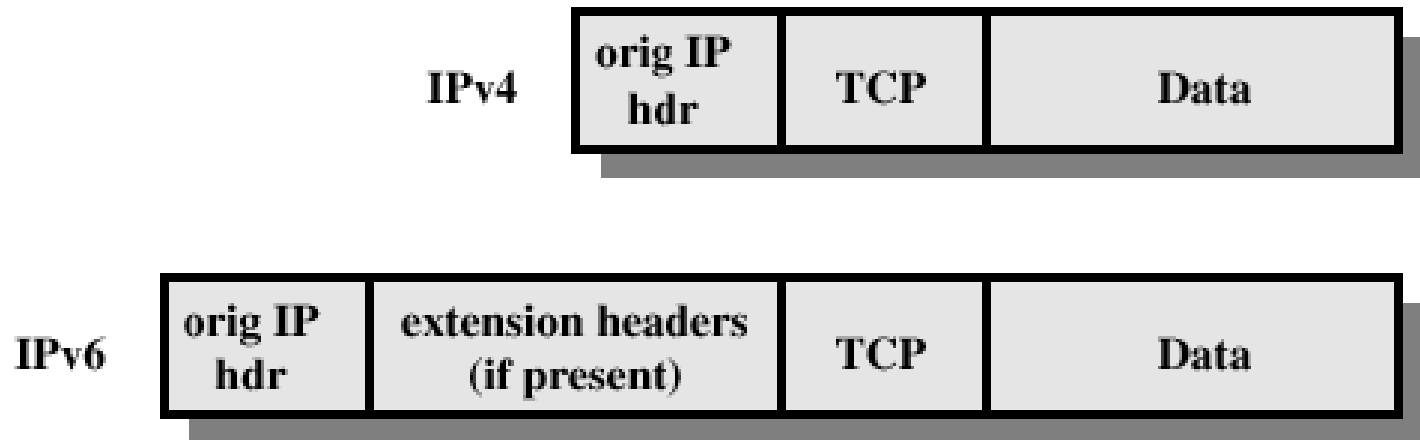


- ESP in tunnel mode encrypts and optionally authenticates the entire inner IP packet

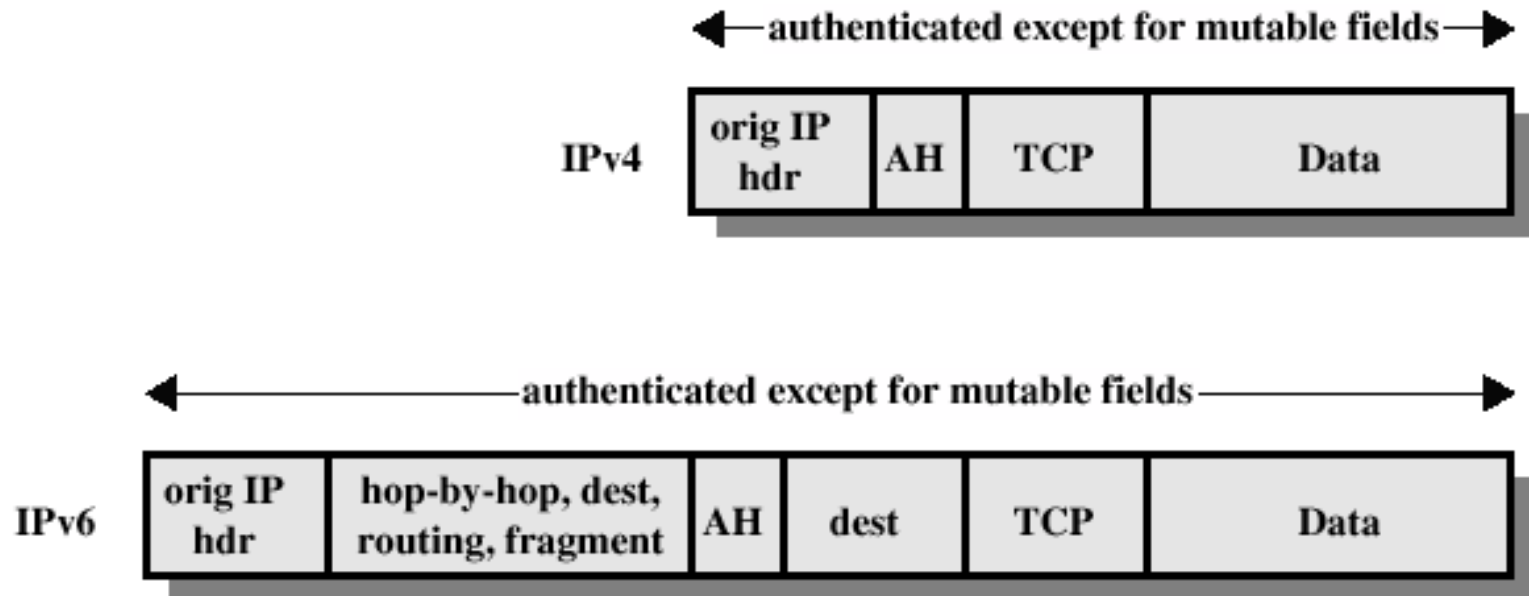


	Transport Mode SA	Tunnel Mode SA
AH	Authenticates IP payload and selected portions of IP header and IPv6 extension headers	Authenticates entire inner IP packet plus selected portions of outer IP header
ESP	Encrypts IP payload and any IPv6 extension header	Encrypts inner IP packet
ESP with authentication	Encrypts IP payload and any IPv6 extension header. Authenticates IP payload but no IP header	Encrypts inner IP packet. Authenticates inner IP packet.

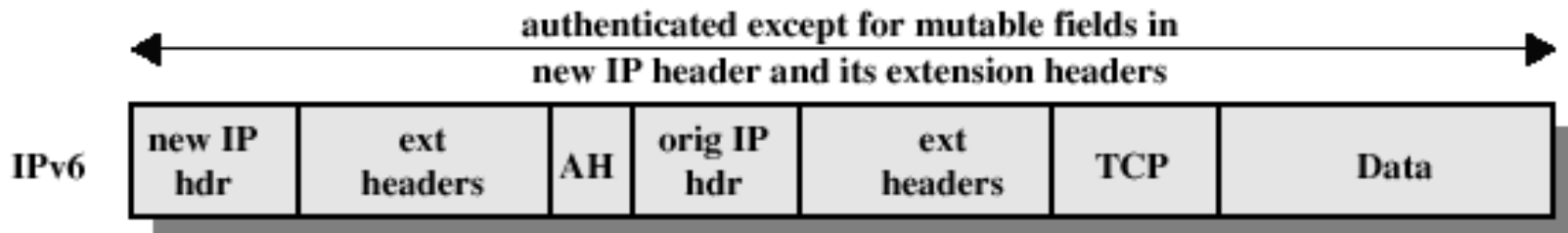
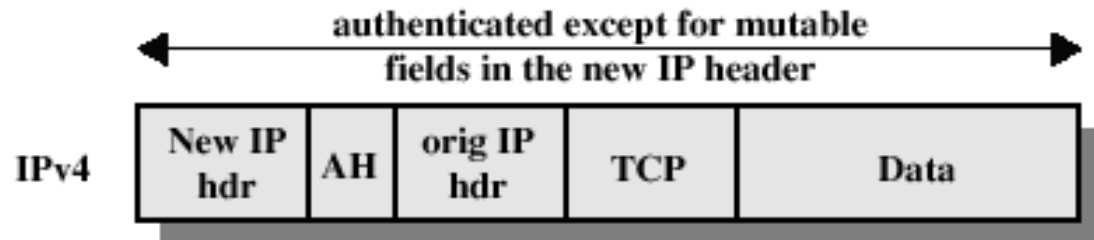
Before applying AH



Transport Mode (AH Authentication)



Tunnel Mode (AH Authentication)

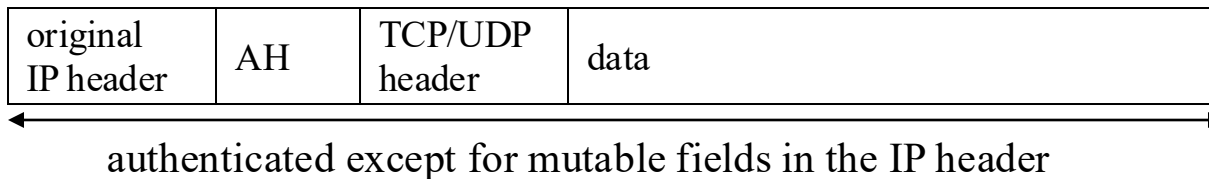


AH in transport and tunnel mode

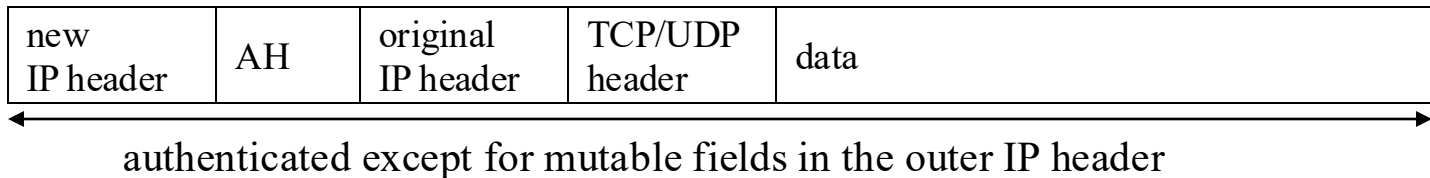
original IPv4 packet

original IP header	TCP/UDP header	data
--------------------	----------------	------

AH in transport mode



AH in tunnel mode



Authentication Header

- Provides support for **data integrity** and **authentication** (MAC code) of IP packets.
- Guards against **replay attacks-provides antiRplay Service**.
- **Integrity Check Value**

EHs commonly used:

1. Hop-by-Hop
2. Routing
3. Fragmentation
4. Destination Options Header
- 5. Authentication**
6. Encapsulating Security Payload

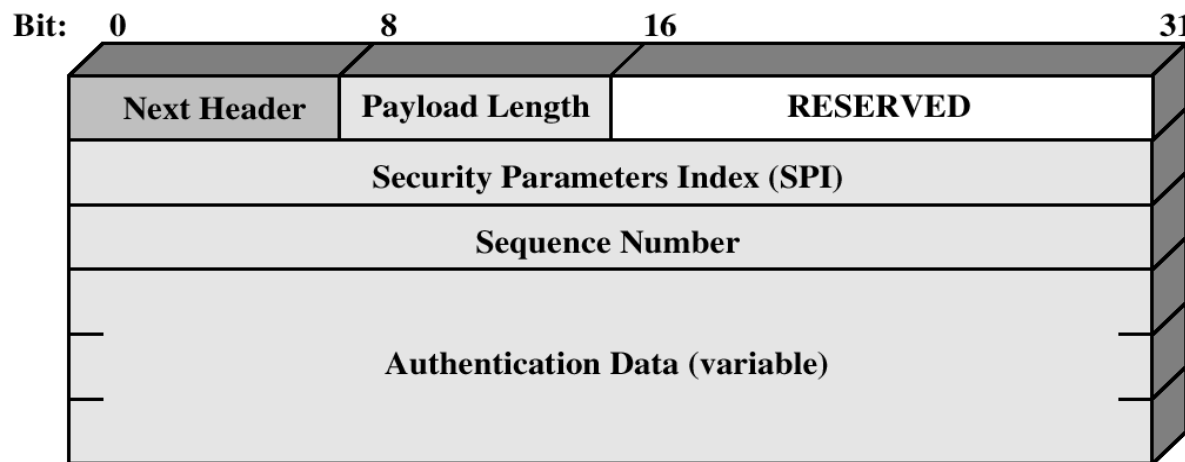
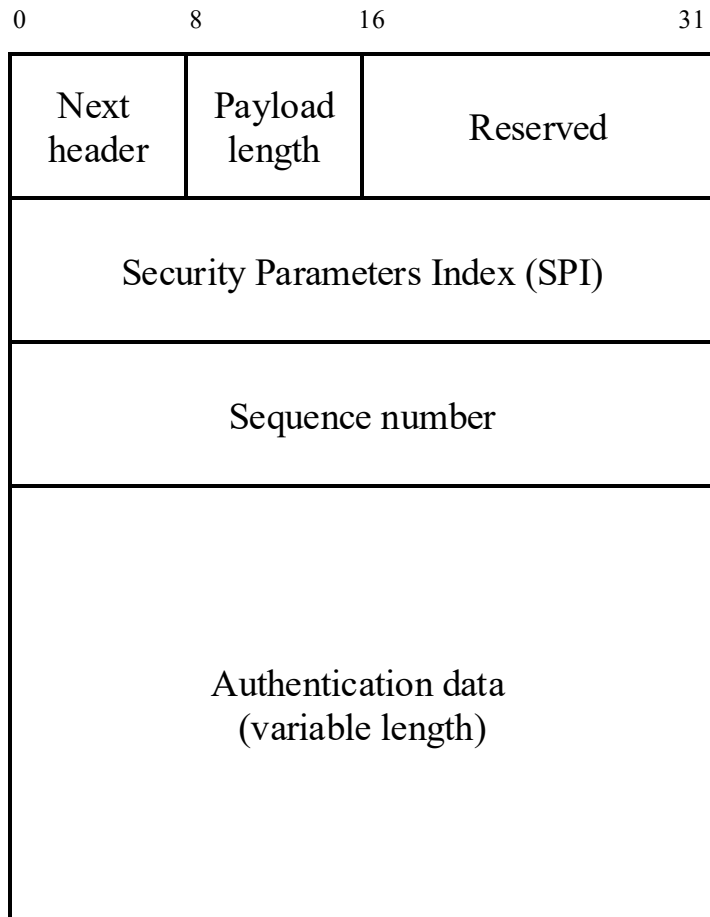


Figure 6.3 IPsec Authentication Header

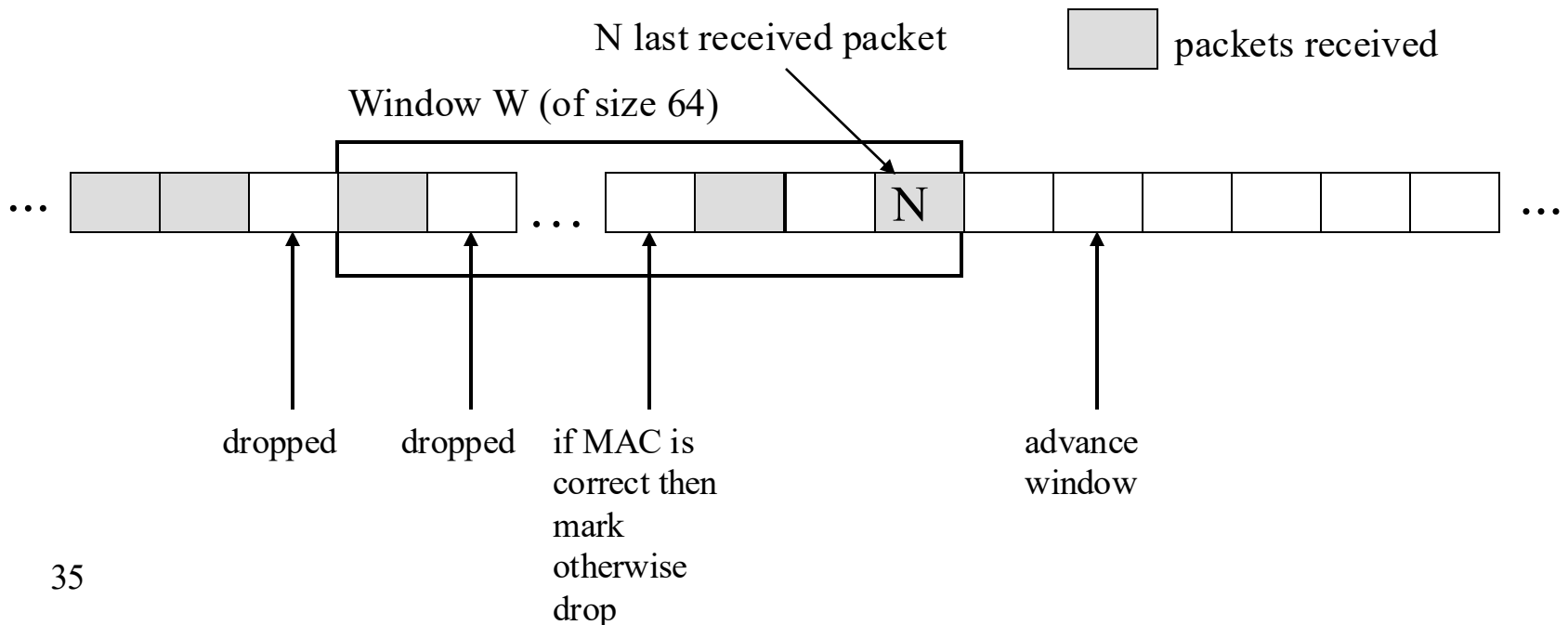
Authentication Header - AH



- Next header
 - type of header immediately following this header (e.g., TCP, IP, etc.)
- Payload length
 - length of AH (in 32 bit words) minus 2
 - e.g., 4 if Authentication data is 3x32 an 3 ealier rows of 32 bits each= 6 rows of 32 bits long
- Security Parameters Index
 - identifies the SA used to generate this header
- Sequence number
 - sequence number of the packet
- Authentication data
 - a (truncated) MAC (default length is 3x32 bits)

Replay detection

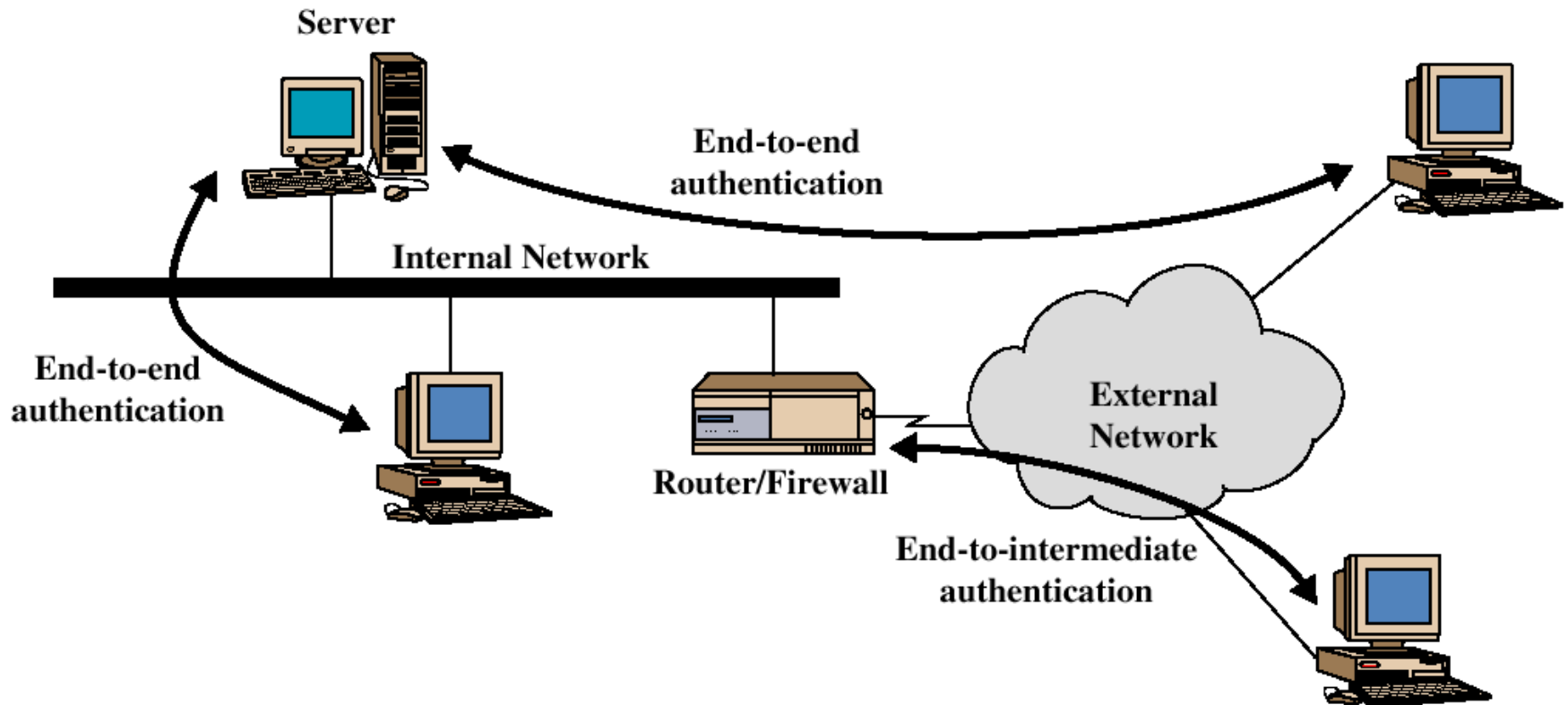
- replay: the attacker obtains an authenticated packet and later transmits (replays) it to the intended destination
- anti-replay mechanism works by keeping track of the sequence numbers in packets as they arrive.
- receiver has an anti-replay window of default size $W = 64$



Integrity Check Value - ICV

- Keyed Message authentication code (MAC)
- Standards used are
 - HMAC-SHA-1-96
 - HMAC-MD5-96
- calculated over
 - IP header field that do not change or are predictable
 - Source IP address, destination IP, header length, etc.
 - Prevent spoofing
 - Mutable fields excluded: e.g., time-to-live (TTL), IP header checksum, etc.
 - IPSec protocol header except the ICV value field
 - Upper-level data
- Code may be truncated to first 96 bits

End-to-end versus End-to-Intermediate Authentication



Encapsulating Security Payload (ESP)

- Provides all that AH offers, and
- in addition provides **data confidentiality**
 - Uses symmetric key encryption

ESP Details

- Same as AH:
 - Use 32-bit sequence number to counter replaying attacks
 - Use integrity check algorithms
- Only in ESP:
 - Data confidentiality:
 - Uses symmetric key encryption algorithms to encrypt packets

Encapsulating Security Payload

- ESP provides confidentiality services

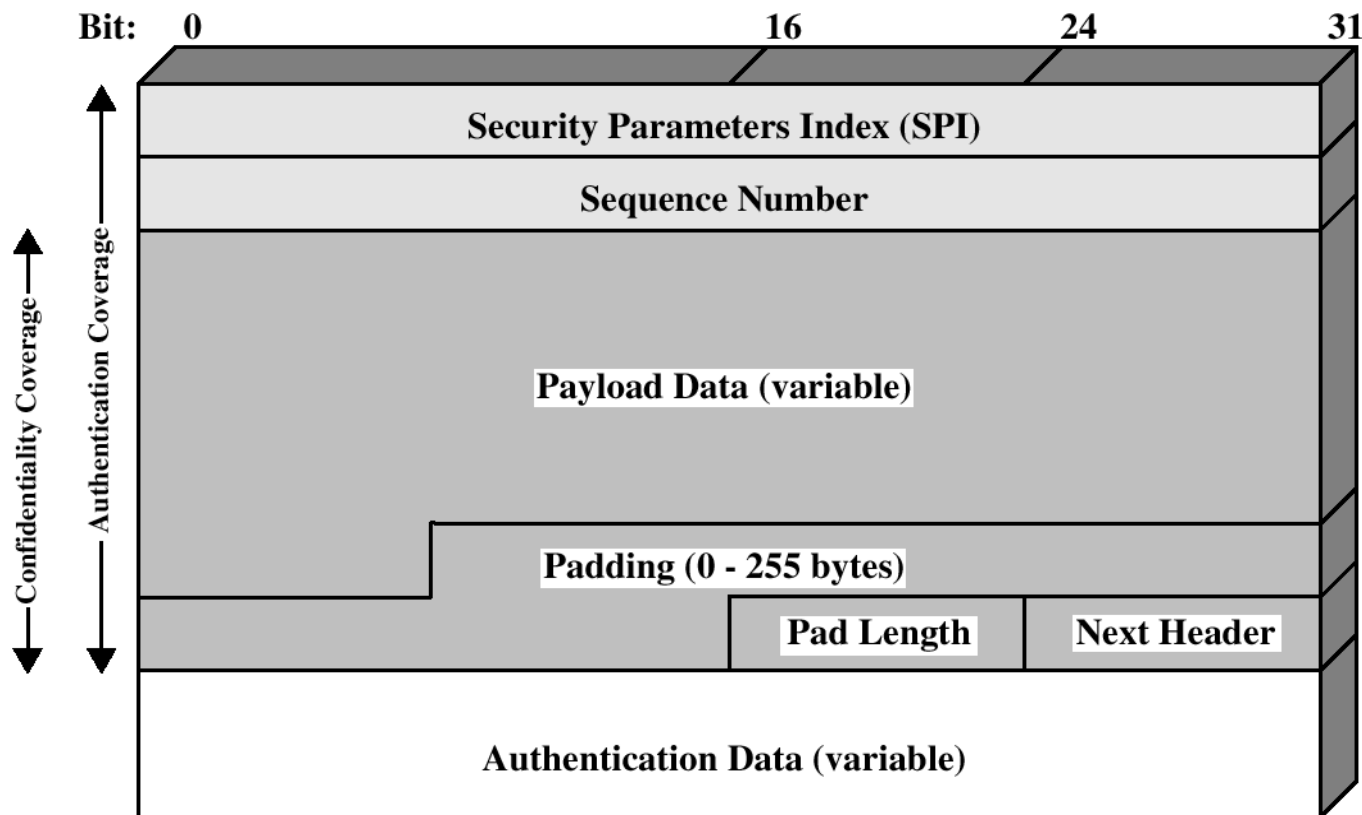
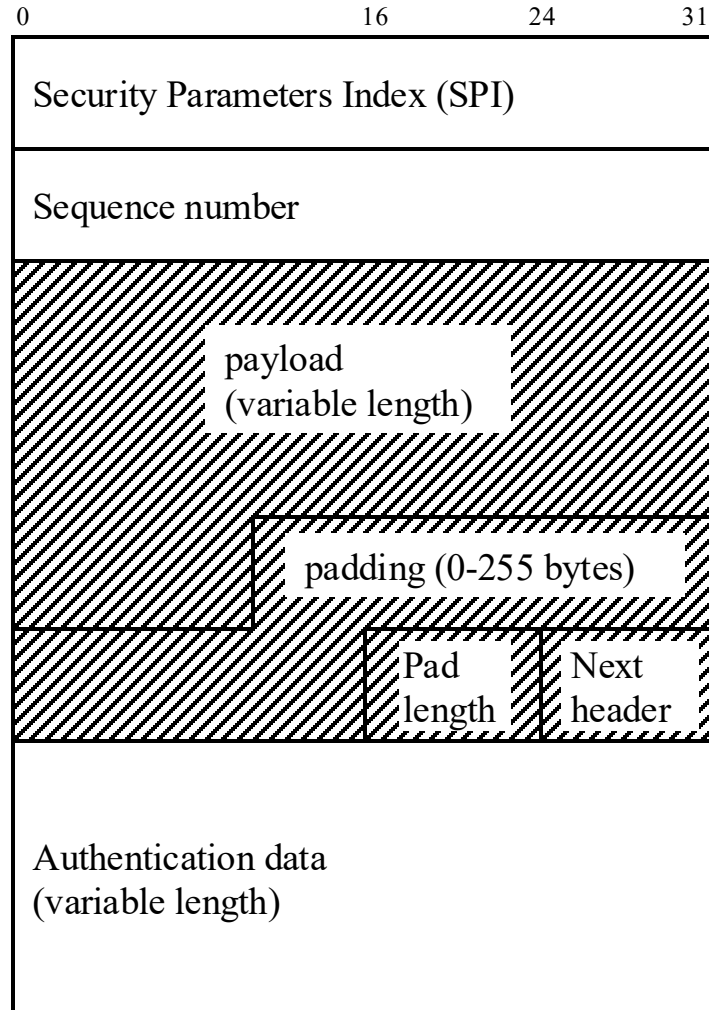


Figure 6.7 IPsec ESP Format

Encapsulating Security Payload - ESP

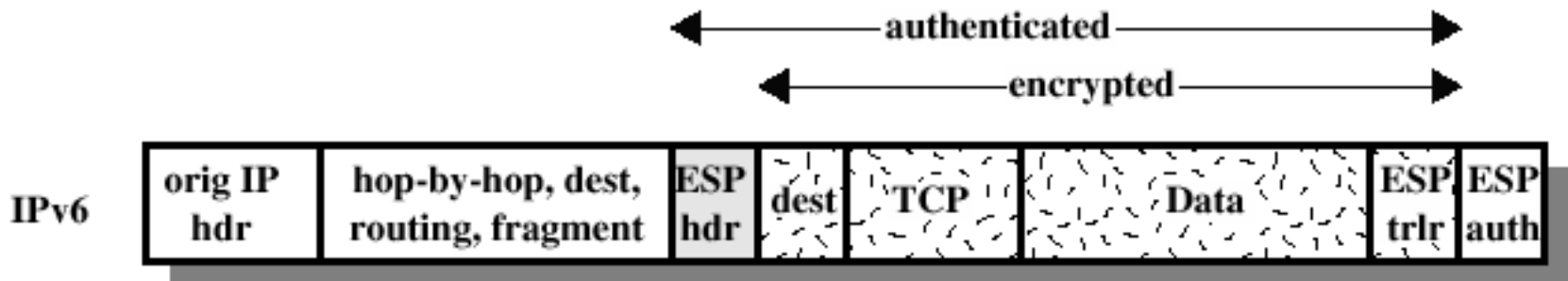
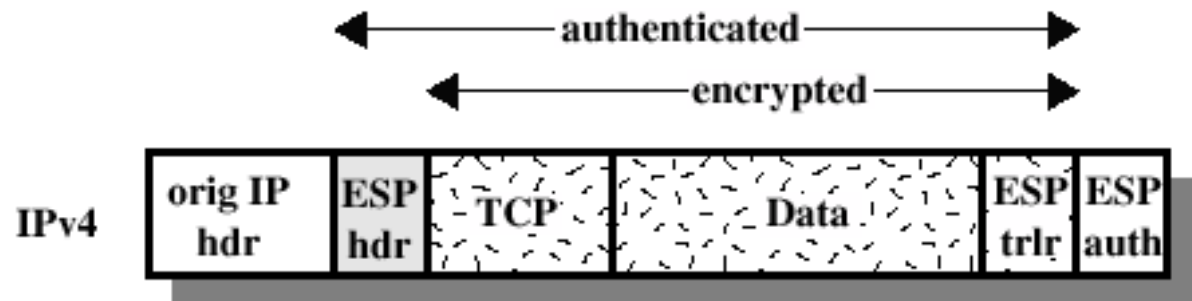


- **Security Parameters Index**
 - identifies the SA used to generate this encrypted packet
- **Sequence number**
- **payload**
 - transport level segment (transfer mode) or encapsulated IP packet (tunnel mode)
- **padding**
 - variable length padding
- **Pad length**
- **Next header**
 - identifies the type of data contained in the header
- **Authentication data**
 - a (truncated) MAC computed over the ESP packet (SPI ... Next Header)

Encryption and MAC algorithms

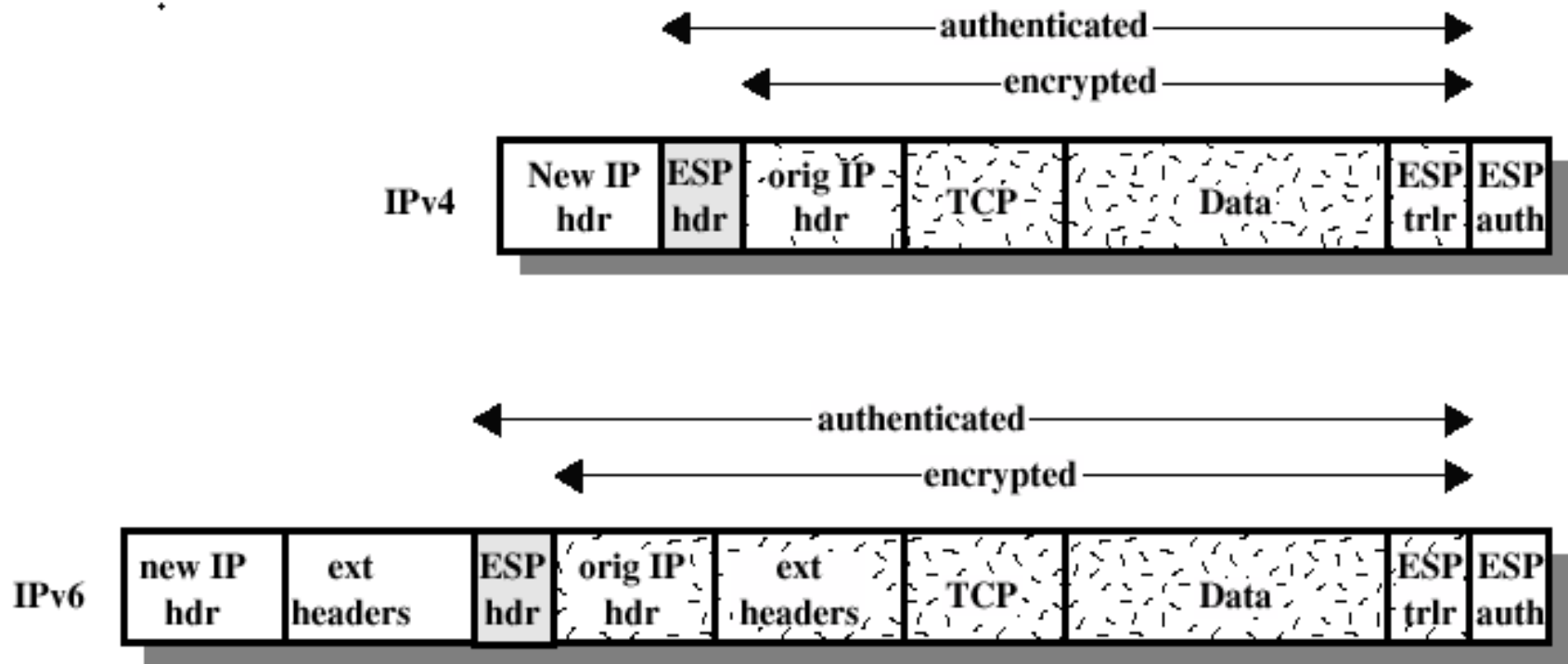
- encryption
 - applied to the payload, padding, pad length, and next header fields
 - implementations must support DES-CBC
 - other suggested algorithms: 3DES, RC5, IDEA, 3IDEA, CAST, Blowfish
- MAC
 - default length is 3x32 bits
 - implementations must support HMAC-MD5-96 and HMAC-SHA1-96
 - MAC is computed over the SPI, sequence number, and encrypted payload, padding, pad length, and next header fields
 - unlike in AH, here the MAC does not cover the preceding IP header

ESP Encryption and Authentication



(a) Transport Mode

ESP Encryption and Authentication



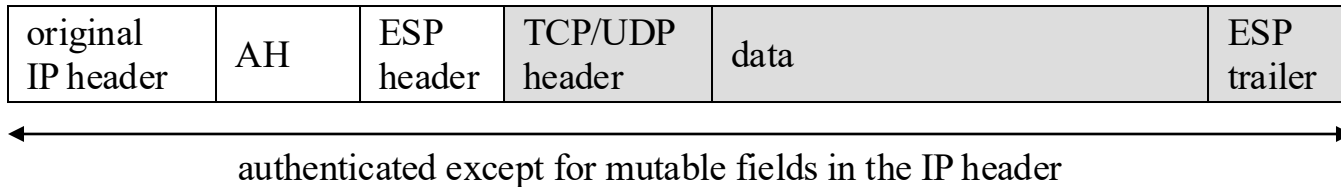
(b) Tunnel Mode

Combining Security Associations

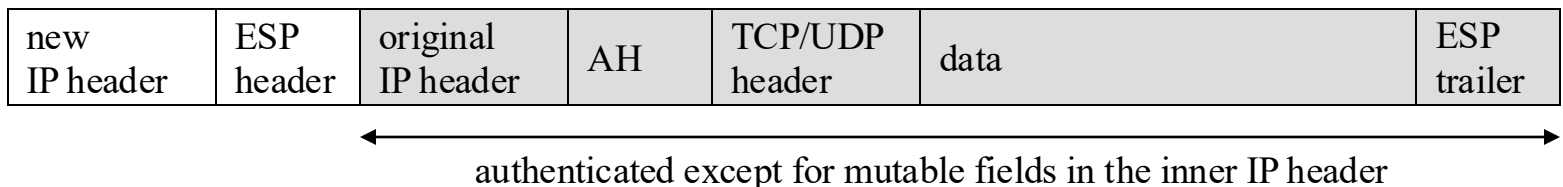
- SA's can implement either AH or ESP
- To implement both need to combine SA's
 - form a security association bundle
 - may terminate at different or same endpoints
 - combined by
 - transport adjacency
 - iterated tunneling
- issue of authentication & encryption order

Combining security associations- Transport Adjacency

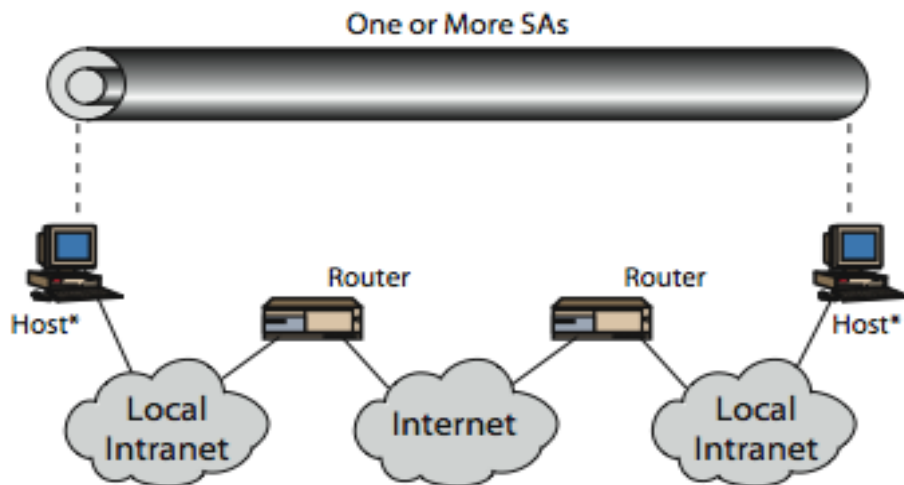
- basic ESP-AH combination
 1. apply ESP in transport mode without authentication
 2. apply AH in transport mode



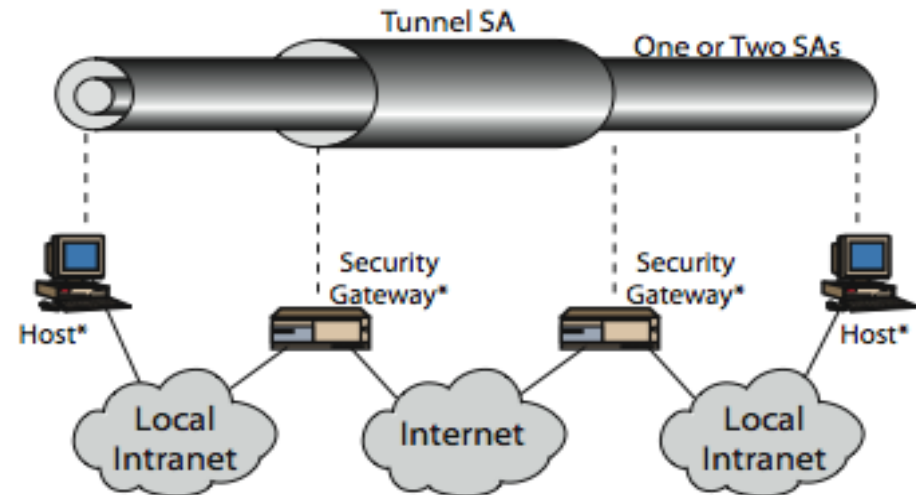
- basic AH-ESP combination
 1. apply AH in transport mode
 2. apply ESP in tunnel mode without authentication



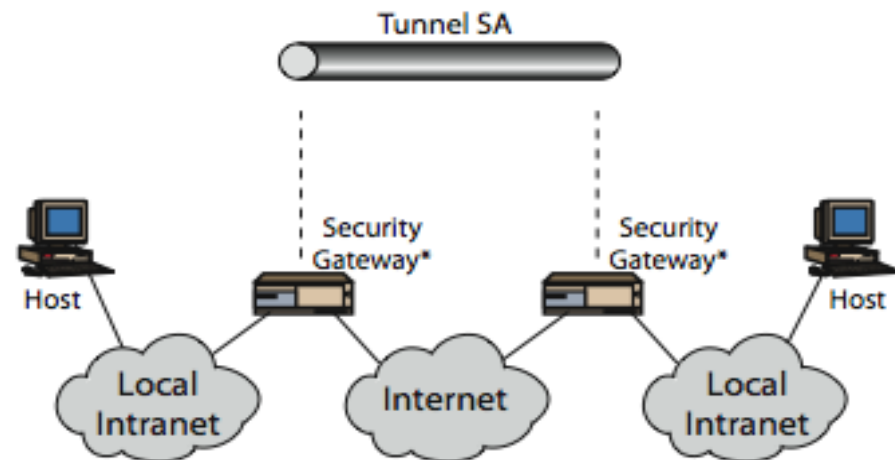
Combining Security Associations- Iterated Tunneling



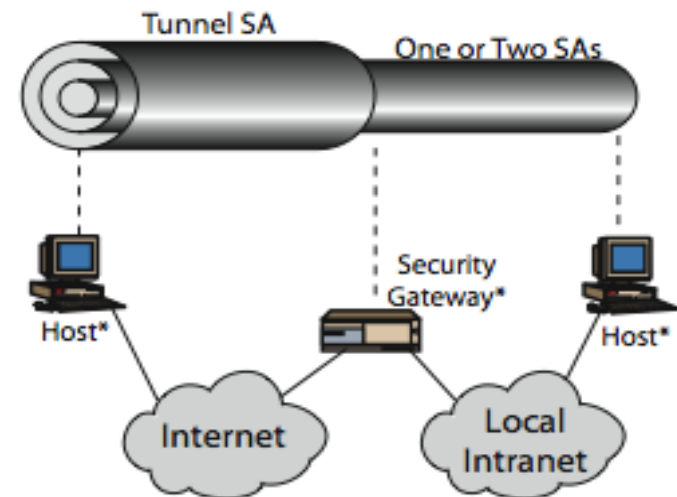
(a) Case 1



(c) Case 3



(b) Case 2



(d) Case 4

* Indicates machine compliant with IPSec protocols

Key Management

- Two types:
 - Manual
 - Automated
 - Oakley Key Determination Protocol
 - Internet Security Association and Key Management Protocol (ISAKMP)

Key management

- two types must be supported by implementations
 1. manual
 - system administrator configures each system with the necessary keys
 2. automated
 - on-demand creation of keys for SAs
- default automated method is ISAKMP/Oakley
 - Oakley key determination protocol
 - a key exchange protocol based on Diffie-Hellman
 - provides added security (e.g., authentication)
 - ISAKMP - Internet Security Association and Key Management Protocol
 - provides a framework for key exchange
 - defines message formats that can carry the messages of various key exchange protocols

Oakley key determination protocol

Problems with basic DH:

1. it is subject to a man-in-the-middle type attack
2. it is vulnerable to a clogging attack
 - attacker sends fake DH messages to a victim from a forged IP address
 - victim starts performing modular exponentiations to compute a secret key
 - victim can be blocked with useless work

Added security features of Oakley

1. cookie exchange to thwart clogging attacks

- $\text{hash}(\text{src IP addr}, \text{dst IP addr}, \text{src UDP port}, \text{dst UDP port}, \text{local secret})$
- local secret is periodically changed

2. uses nonces to detect replay attacks

3. authenticates the DH exchange to thwart man-in-the-middle attacks

- based on digital signatures, public key encryption, or symmetric key encryption

4. enables the parties to negotiate the global parameters of the DH exchange (e.g., the prime p that defines the group and the generator g of the group)

- few predefined groups

Cookie generation

The cookie must satisfy 3 basic requirements:

1. A cookie must depend on specific parties, the UDP source and destination ports, and
2. a locally generated secret value.
3. a fast hash (e.g. MD5) over the IP source and destination addresses

Three authentication methods:

- Digital signatures
- Public-key encryption
- Symmetric-key encryption

OAKLEY supports different groups for the Diffie-Hellman key exchange

- DH Group 1: 768-bit group
- DH Group 2: 1024-bit group
- DH Group 5: 1536-bit group
- DH Group 14: 2048-bit group
- DH Group 15: 3072-bit group
- DH Group 19: 256-bit elliptic curve group
- DH Group 20: 384-bit elliptic curve group

Oakley Key Exchange example - Aggressive

$I \rightarrow R: CKY_i | OK_KEYX | NIDP | GRP | g^x | EHAO | ID_i | ID_r | N_i |$
 $Sig(K_i^{-1}, ID_i | ID_r | N_i | GRP | g^x | EHAO)$

$R \rightarrow I: CKY_r | CKY_i | OK_KEYX | GRP | g^y | EHAS | NIDP | ID_r | ID_i | N_r | N_i |$
 $Sig(K_r^{-1}, ID_r | ID_i | N_r | N_i | GRP | g^y | g^x | EHAS)$

$I \rightarrow R: CKY_i | CKY_r | OK_KEYX | GRP | g^x | NIDP | ID_i | ID_r | N_i | N_r |$
 $Sig(K_i^{-1}, ID_i | ID_r | N_i | N_r | GRP | g^x | g^y | EHAS)$

where

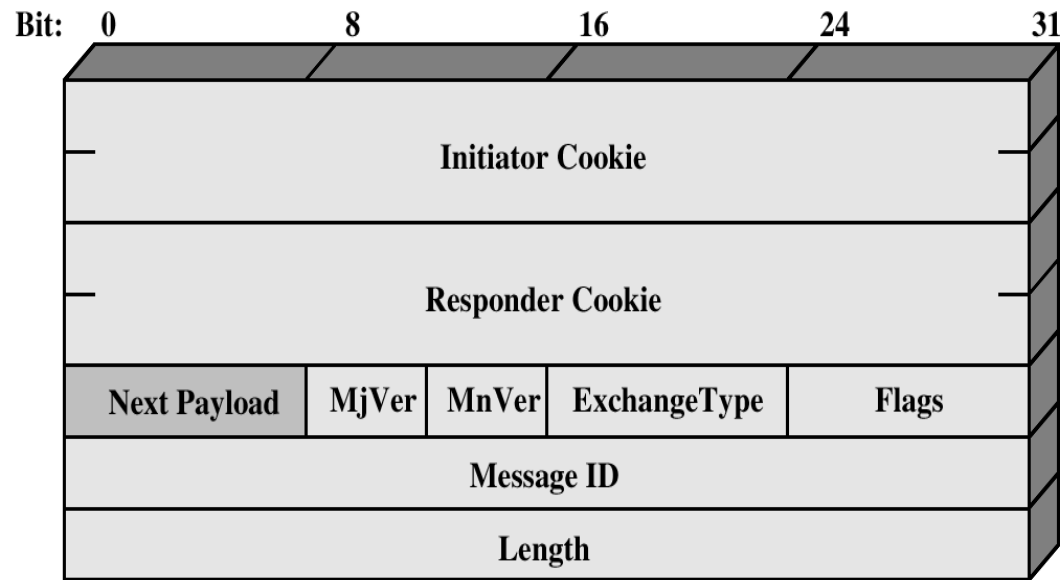
- I,R: Initiator, Responder
- CKY: cookie
- OK_KEYX: message type is Oakley key exchange
- GRP: group
- g^x g^y : public key of I and R
- EHAO/EHAS: encryption, hash, authentication alg. offered/selected
- NIDP: no ID protection
- N: nonce

⁵⁴
Why aggressive? Because only 3 messages are exchanged

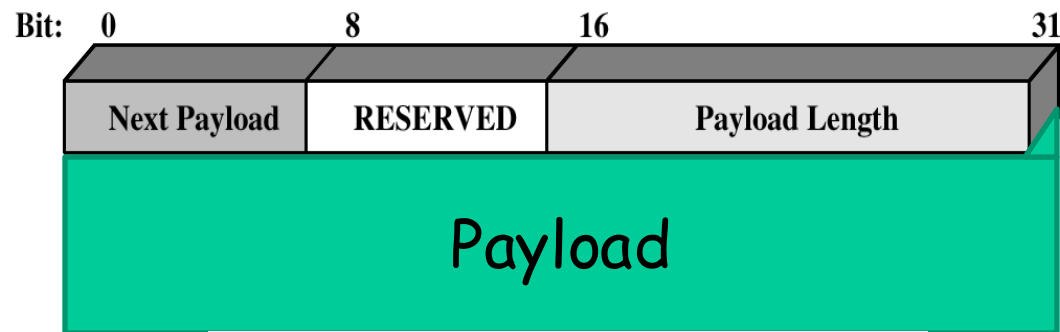
ISAKMP

- Defines procedures and packet formats to establish, negotiate, modify and delete SAs.
- ISAKMP only provides a framework for exchanging key generation and authentication data.
- ISAKMP is distinct from key exchange protocols.
- There may be many different key exchange protocols, each with different security properties.
- However, a common framework (: ISAKMP) is required for agreeing to the format of SA attributes, and for negotiating, modifying, and deleting SAs

ISAKMP generic message format



(a) ISAKMP Header



(b) Generic Payload Header

Next payload

- type of next payload (e.g., transform, key exchange, certificate, ...)
- 0 if this is the last payload

Exchange type

- 5 default exchange types (base, ID protection, auth only, aggressive, informational)

Message ID

- unique ID of this message

Length

- length of header + all payloads

ISAKMP payload types

1. **Security Association (SA)**- used to begin the setup of a new SA; carries various attributes
2. **Proposal (P)**- used during SA setup; indicates protocol to be used (AH or ESP) and number of transforms
3. **Transform (T)**- used during SA setup; indicates transform (e.g., DES, 3DES) and its attributes
4. **Key exchange (KE)**- used to carry key exchange data (e.g., Oakley)
5. **Identification (ID)**- used to exchange identification information (e.g., IP address)
6. **Certificate (CR)**- carries a public key certificate (PGP, X.509, Kerberos tokens, ...)
7. **Hash (HASH)**
8. **Signature (SIG)**
9. **Nonce (NONCE)**
10. **Notification (N)**- contains error or status information
11. **Delete (D)**- indicates one or more SAs that the sender has deleted from its database (no longer valid)

ISAKMP exchange types

1. base exchange
2. identity protection exchange
3. authentication only exchange
4. aggressive exchange
5. informational exchange

ISAKMP exchange types contd.

- base exchange

$I \rightarrow R : SA; NONCE$

$R \rightarrow I : SA; NONCE$

$I \rightarrow R : KE; ID_i; AUTH$

$R \rightarrow I : KE; ID_r; AUTH$

- identity protection exchange

$I \rightarrow R : SA$

$R \rightarrow I : SA$

$I \rightarrow R : KE; NONCE$

$R \rightarrow I : KE; NONCE$

$I \rightarrow R : ID_i; AUTH$

$R \rightarrow I : ID_r; AUTH$

ISAKMP exchange types contd.

- authentication only exchange

$I \rightarrow R : SA; NONCE$

$R \rightarrow I : SA; NONCE; ID_r; AUTH$

$I \rightarrow R : ID_i; AUTH$

- aggressive exchange

$I \rightarrow R : SA; KE; NONCE; ID_i$

$R \rightarrow I : SA; KE; NONCE; ID_r; AUTH$

$I \rightarrow R : AUTH$

- informational exchange

$I \rightarrow R : N/D$